

S5L3 - Obiettivo: Vulnerability Scanning con Nessus sulla macchina Metasploitable (IP: 192.168.100.2)

1. Accesso all'interfaccia Web di Nessus

- Indirizzo: <https://kali:8834>
- Accesso effettuato tramite credenziali fornite

2. Creazione di una nuova scansione

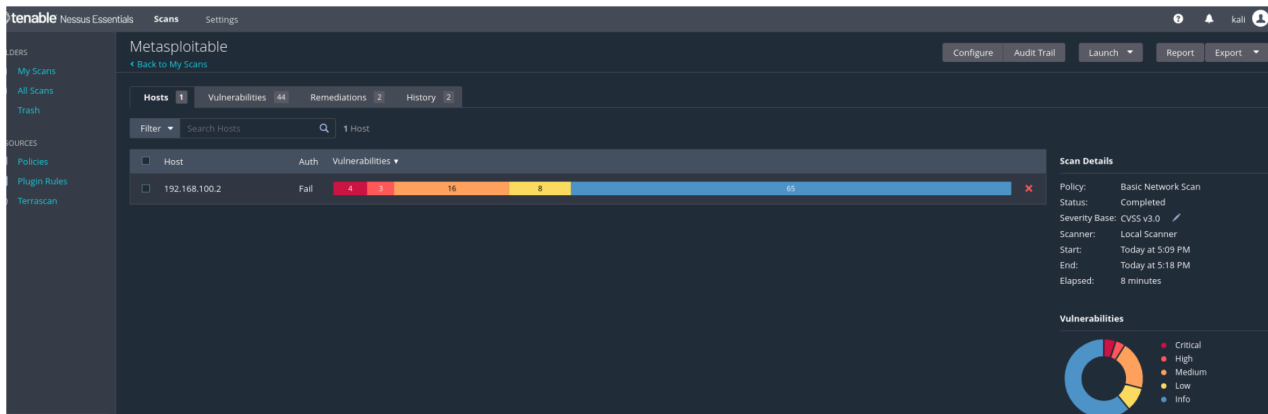
- Dopo l'accesso, si è cliccato su "**New Scan**"
- È stato selezionato il tipo di scansione "**Advanced Scan**" (scansione dettagliata), per ottenere un'analisi più completa
- Target impostato: **192.168.100.2** (indirizzo IP della macchina Metasploitable)
- Specificate le **porte comuni** da analizzare (es. 22, 80, 443, ecc.)

3. Esecuzione della scansione

- La configurazione della scansione è stata **salvata**.
- È stato cliccato su "**Launch**" per avviare la scansione sul target.

4. Analisi dei risultati

- Al termine della scansione, sono state rilevate **44 vulnerabilità totali**.
- Di queste, **diverse risultano critiche**. Di seguito l'analisi dettagliata delle principali



5. Vulnerabilità Critiche Identificate

Vulnerabilità 1: Canonical Ubuntu Linux EOL (8.04.x)

- **ID Nessus:** 201352
- **Descrizione:**
Il sistema target utilizza una versione obsoleta di Ubuntu (8.04.x), non più supportata da Canonical. L'assenza di aggiornamenti e patch di sicurezza espone la macchina a numerose vulnerabilità note, comprese alcune critiche.
- **Gravità:** Critica
- **Servizio interessato:** Sistema operativo (nessuna porta specifica)
- **Contromisure:**
 - Aggiornare il sistema operativo a una versione supportata
 - Pianificare una migrazione verso una distribuzione Linux mantenuta

201352 - Canonical Ubuntu Linux SEoL (8.04.x)

Synopsis

An unsupported version of Canonical Ubuntu Linux is installed on the remote host.

Description

According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

See Also

<http://www.nessus.org/u?3bdb2d2e>

Solution

Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

Risk Factor

Critical

100 168 100 3

4

CVSS v3.0 Base Score

10.0 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

Plugin Information

Published: 2024/07/03, Modified: 2025/03/26

Plugin Output

tcp/22/ssh

OS	: Ubuntu Linux 8.04
Security End of Life	: May 9, 2013
Time since Security End of Life (Est.)	: >= 12 years

Vulnerabilità 2: Debian OpenSSH/OpenSSL - Weak Random Number Generation

- **ID Nessus:** 32314
- **Descrizione:**

La vulnerabilità riguarda un noto bug nelle versioni Debian che compromette la generazione di numeri casuali per chiavi SSH/SSL. Questo rende le chiavi prevedibili, facilitando attacchi da parte di terzi.
- **Gravità:** Critica
- **Porte coinvolte:** 22 (SSH), 443 (HTTPS)
- **Contromisure:**
 - Aggiornare OpenSSH/OpenSSL.
 - Rigenerare tutte le chiavi crittografiche.
 - Revocare e sostituire i certificati compromessi.

32314 - Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Synopsis

The remote SSH host keys are weak.

Description

The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

See Also

<http://www.nessus.org/u?107f9bdc>

<http://www.nessus.org/u?f14f4224>

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

Risk Factor

Critical

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

CVSS v2.0 Temporal Score

8.3 (CVSS2#E:F/RL:OF/RC:C)

References

BID	29179
CVE	CVE-2008-0166
XREF	CWE:310

Exploitable With

Core Impact (true)

Plugin Information

Published: 2008/05/14, Modified: 2024/07/24

Plugin Output

tcp/22/ssh

Vulnerabilità 3: Debian OpenSSH/OpenSSL - Weak Random Number Generation (SSL Check)

- **ID Nessus:** 32321
- **Descrizione:**
Ulteriore conferma della vulnerabilità precedente, rilevata tramite verifica SSL. La debole generazione casuale compromette la sicurezza delle sessioni cifrate, esponendo a potenziali attacchi Man-in-the-Middle
- **Gravità:** Critica
- **Porte coinvolte:** 22 (SSH), 443 (HTTPS)
- **Contromisure:**
 - Aggiornare le librerie OpenSSL/OpenSSH
 - Rigenerare tutte le chiavi SSH/SSL
 - Applicare policy per l'uso esclusivo di protocolli e algoritmi sicuri

32321 - Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)

Synopsis

The remote SSL certificate uses a weak key.

Description

The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

See Also

<http://www.nessus.org/u?107f9bdc>

<http://www.nessus.org/u?f14f4224>

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

Risk Factor

Critical

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

CVSS v2.0 Temporal Score

8.3 (CVSS2#E:F/RL:OF/RC:C)

References

BID	29179
CVE	CVE-2008-0166
XREF	CWE:310

Exploitable With

Core Impact (true)

Plugin Information

Published: 2008/05/15, Modified: 2020/11/16

Plugin Output

tcp/25/smtp

Vulnerabilità 4: SSL Version 2 and 3 Protocols Enabled

- **ID Nessus:** 20007
- **Descrizione:**

Il sistema supporta ancora i protocolli SSLv2 e SSLv3, considerati insicuri e deprecati. Questi protocolli sono vulnerabili a noti attacchi come POODLE, rendendo insicure le comunicazioni cifrate
- **Gravità:** Critica
- **Porta coinvolta:** 443 (HTTPS)
- **Contromisure:**
 - Disabilitare SSLv2 e SSLv3
 - Abilitare solo TLS 1.2 o versioni superiori (es. TLS 1.3)
 - Eseguire test periodici della configurazione SSL/TLS

20007 - SSL Version 2 and 3 Protocol Detection

Synopsis

The remote service encrypts traffic using a protocol with known weaknesses.

Description

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

See Also

<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<http://www.nessus.org/u7b06c7e95>
<http://www.nessus.org/u7247c4540>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<http://www.nessus.org/u75d15ba70>
<https://www.imperialviolet.org/2014/10/14/poodle.html>
<https://tools.ietf.org/html/rfc7507>
<https://tools.ietf.org/html/rfc7568>

Solution

Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

Risk Factor

Critical

CVSS v3.0 Base Score

192.168.100.2

10

9.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

Plugin Information

Published: 2005/10/12, Modified: 2022/04/04

Plugin Output

tcp/25/smtp

- SSLv2 is enabled and the server supports at least one cipher.

Low Strength Ciphers (<= 64-bit key)

Name	Code	Key	Auth	Encryption	MAC
EXP-RC2-CBC-MD5		RSA(512)	RSA	RC2-CBC(40)	MD5
export					
EXP-RC4-MD5		RSA(512)	RSA	RC4(40)	MD5
export					

Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

Name	Code	Key	Auth	Encryption	MAC
DES-CBC3-MD5		RSA	RSA	3DES-CBC(168)	MD5

High Strength Ciphers (>= 112-bit key)

Name	Code	Key	Auth	Encryption	MAC
RC4-MD5		RSA	RSA	RC4(128)	MD5

The fields above are :

[Tenable ciphername]
[Cipher ID code]
Key=key exchange
Auth=authentication
Encrypt=asymmetric encryption method
MAC=message authentication code
(export flag)

- SSLv3 is enabled and the server supports at least one cipher.

Explanation: TLS 1.0 and SSL 3.0 cipher suites may be used with SSLv3

Low Strength Ciphers (<= 64-bit key)

Name	Code	Key	Auth	Encryption	MAC
EXP-EDH-RSA-DES-CBC-SHA		DH(512)	RSA	DES-CBC(40)	
SSL export					
EDH-RSA-DES-CBC-SHA		DH	RSA	DES-CBC(56)	SHA
[...]					

6. Conclusioni

La scansione ha evidenziato **gravi vulnerabilità** su una macchina con un sistema operativo datato e servizi mal configurati. Gli interventi suggeriti includono aggiornamenti software, sostituzione di chiavi crittografiche e miglioramento della configurazione dei protocolli di sicurezza

Una corretta gestione delle vulnerabilità richiede:

- **Aggiornamenti regolari** del sistema operativo e dei servizi esposti
- **Controlli di sicurezza periodici** tramite strumenti come Nessus
- **Adozione di best practice** in materia di cifratura, autenticazione e gestione degli accessi